

. [את הצעתכם](#) והגישו [ATT&CKcon 7.0](#) יגיע בין ה-27 ל-28 באוקטובר 2026. למדו עוד על ATT&CKcon 7.0

אתר זה משתמש בטכנולוגיות כגון קובצי Cookie כדי לאפשר פונקציונליות חיונית של האתר, כמו גם עבור אנליטיקה, התאמה אישית ופרסום ממוקד. [מדינה פרטיות](#)

קבל

סרב לקבצי עוגיות לא חיוניות

נחל העדפות

[בֵּית](#) > [תוכנה](#) > XCSSET

אתר זה משתמש בטכנולוגיות כגון קובצי Cookie כדי לאפשר פונקציונליות חיונית של האתר, כמו גם עבור אנליטיקה, התאמה אישית ופרסום ממוקד. [מדינה פרטיות](#)

היא משפחת תוכנות זדוניות ומודלריות של macOS המועברת דרך פרויקטים נגועים של Xcode ומבוצעת כאשר הפרויקט עובר קומפילציה. הפרויקט פעיל [XCSET](#) מאוגוסט 2020, ונצפתה מתקינה דלתות אחוריות, דפדפנים מזויפים, אוספת נתונים ומצפנת קבצי משתמשים. ה-XCSET מורכב מסקריפטי מעטפת שעברו קומפילציה של SHC ומ-AppleScripts להפעלה בלבד, ולעתים קרובות מסתתרת באפליקציות המחקות כלי מערכת (כגון Xcode, Mail או Notes) או משתמשת בסמלים מוכרים (כגון Launchpad) כדי להימנע מגילוי.

מזהה: S0658	
תוכנה קשורה : OSX.DubRobber	
תוכנה זדוניתסוג :	
פלטפורמות : macOS	
גרסה : 1.3	
05 באוקטובר 2021נוצר:	
04 אפריל 2025עודכן לאחרונה:	

תיאורי תוכנה נלווים

שם	תאור
OSX.DubRobber	[4]

טכניקות בשימוש

להשתמש	שם	תעודת זהות	תחום
מנסה לגשת או להציג את תוכן תיקיות המשתמש כגוןXCSSETעבור מספר מודולים, שולחן עבודה, הורדות ומסמכים. אם התיקייה אינה קיימת או שהגישה נדחית, היא נכנסת ללולאה שבה היא מאפסת את מסד הנתונים של TCC ומנסה גישה שוב. ^[3]	: מנגנון בקרת גובה שימוש לרעה מניפולציה של TCC	T1548.006	מפעל
מנסה לגלות חשבונות ממיקומים שונים כגון נתוני XCSSETEvernote, AppleID, Telegram, Skype ו-WeChat של המשתמש. ^[1]	גילוי חשבון	T1087	מפעל
XCSSET ssh-keygen -t rsa -f ייצור מפתח SSH במידת הצורך באמצעות XCSSET יעלה קובץ מפתח פרטי לשרת כדיXCSSETהפקודה. \$HOME/.ssh/id_rsa -P ^[1] לגשת מרחוק למארח ללא סיסמה.	מפתחות מורשים : מניפולציה בחשבון באמצעות SSH	T1098.004	מפעל
התיקיות, אך רק אם .git. תיקיות שלמות למעט כל ~/Desktop ידחם XCSSET ^[1] גודל הנתונים הכולל קטן מ-200MB	ארכיון נתונים שנאספו	T1560	מפעל
משתמש בסקריפט מעטפת כדי להריץ קבצי Mach-ופקודותXCSSET ^[1] . osacompile -x -o xcode.app main.applescript. כגון, osacompile	מעטפת : מפרש פקודות וסקריפטים יוניקס	T1059.004	מפעל
משתמש ביישום דפדפן זדוני כדי להחליף את הדפדפן הליגיטימי על מנתXCSSET ^[1] ללכוד באופן רציף אישורים, לנטר תעבורת אינטרנט ולהוריד מודולים נוספים.	קובץ בינארי של תוכנת מארח פשרה	T1554	מפעל
XCSSET uses the ssh launchdaemon to elevate privileges, bypass system controls, and enable remote access to the victim. ^[1]	: יצירה או שינוי של תהליך מערכת הפעלת Daemon	T1543.004	מפעל
XCSSET performs AES-CBC encryption on files under ~/Documents , ~/Downloads , and ~/Desktop with a fixed key and renames files to give them a .enc extension. Only files with sizes less than 500MB are encrypted. ^[1]	Data Encrypted for Impact	T1486	Enterprise
XCSSET collects contacts and application data from files in Desktop, Documents, Downloads, Dropbox, and WeChat folders. ^[1]	Data from Local System	T1005	Enterprise
XCSSET uses RC4 encryption over TCP to communicate with its C2 server. ^[1]	Encrypted Channel: Symmetric Cryptography	T1573.001	Enterprise
XCSSET's dfhsebxzod module searches for .xcodeproj directories within the user's home folder and subdirectories. For each match, it locates the corresponding project.pbxproj file and embeds an encoded payload into a build rule, target configuration, or project setting. The payload is later executed during the build process. ^{[3][2]}	Event Triggered Execution	T1546	Enterprise
Using AppleScript, XCSSET adds it's executable to the user's ~/.zshrc_aliases file ("echo " & payload & " > ~/.zshrc_aliases"), it then adds a line to the .zshrc file to source the .zshrc_aliases file ([-f \$HOME/.zshrc_aliases] && . \$HOME/.zshrc_aliases). Each time the user starts a new zsh terminal session, the .zshrc file executes the .zshrc_aliases file. ^[3]	Unix Shell Configuration Modification	.004	
XCSSET retrieves files that match the pattern defined in the INAME_QUERY variable within the user's home directory, such as *test.txt , and are below a specific size limit. It then archives the files and exfiltrates the data over its C2 channel. ^{[1][3]}	Exfiltration Over C2 Channel	T1041	Enterprise

אתר זה משתמש בטכנולוגיות כגון קובצי Cookie כדי לאפשר פונקציונליות חיונית של האתר, כמו גם עבור אנליטיקה, התאמה אישית ופרסום ממוקד. [מדינה פרטיות](#)

תחום	תעודת זהות		שם	להשתמש
Enterprise	T1222	.002	File and Directory Permissions Modification: Linux and Mac Permissions	XCSSET uses the <code>chmod +x</code> command to grant executable permissions to the malicious file. ^[6]
Enterprise	T1564	.001	Hide Artifacts: Hidden Files and Directories	XCSSET uses a hidden folder named <code>.xcassets</code> and <code>.git</code> to embed itself in Xcode. ^[1]
Enterprise	T1574	.006	Hijack Execution Flow: Dynamic Linker Hijacking	XCSSET adds malicious file paths to the <code>DYLD_FRAMEWORK_PATH</code> and <code>DYLD_LIBRARY_PATH</code> environment variables to execute malicious code. ^[1]
Enterprise	T1105		Ingress Tool Transfer	XCSSET downloads browser specific AppleScript modules using a constructed URL with the <code>curl</code> command, <code>https://" & domain & "/agent/scripts/" & moduleName & ".applescript</code> . ^[1]
Enterprise	T1056	.002	Input Capture: GUI Input Capture	XCSSET prompts the user to input credentials using a native macOS dialog box leveraging the system process <code>/Applications/Safari.app/Contents/MacOS/SafariForWebKitDevelopment</code> . ^[1]
Enterprise	T1036		Masquerading	XCSSET installs malicious application bundles that mimic native macOS apps, such as Safari, by using the legitimate app's icon and customizing the <code>Info.plist</code> to match expected metadata. ^{[1][3]}
Enterprise	T1027	.013	Obfuscated Files or Information: Encrypted/Encoded File	Older XCSSET variants use <code>xxd</code> to encode modules. Later versions pass an <code>xxd</code> or <code>base64</code> encoded blob through multiple decoding stages to reconstruct the module name, AppleScript, or shell command. For example, the initial network request uses three layers of hex decoding before executing a <code>curl</code> command in a shell. ^[3]
Enterprise	T1647		Plist File Modification	In older versions, XCSSET uses the <code>plutil</code> command to modify the <code>LSUIElement</code> , <code>DFBundleDisplayName</code> , and <code>CFBundleIdentifier</code> keys in the <code>/Contents/Info.plist</code> file to change how XCSSET is visible on the system. In later versions, XCSSET leverages a third-party notarized <code>dockutil</code> tool to modify the <code>.plist</code> file responsible for presenting applications to the user in the Dock and LaunchPad to point to a malicious application. ^{[1][3]}
Enterprise	T1113		Screen Capture	XCSSET saves a screen capture of the victim's system with a numbered filename and <code>.jpg</code> extension. Screen captures are taken at specified intervals based on the system. ^[1]
Enterprise	T1518		Software Discovery	XCSSET uses <code>ps aux</code> with the <code>grep</code> command to enumerate common browsers and system processes potentially impacting XCSSET 's exfiltration capabilities. ^[1]
		.001	Security Software Discovery	XCSSET searches firewall configuration files located in <code>/Library/Preferences/</code> and uses <code>csrutil status</code> to determine if System Integrity Protection is enabled. ^[1]
Enterprise	T1539		Steal Web Session Cookie	XCSSET uses <code>scp</code> to access the <code>~/Library/Cookies/Cookies.binarycookies</code> file. ^[1]
Enterprise	T1553	.001	Subvert Trust Controls: Gatekeeper Bypass	XCSSET has dropped a malicious applet into an app's <code>/Contents/MacOS/</code> folder of a previously launched app to bypass

אתר זה משתמש בטכנולוגיות כגון קובצי Cookie כדי לאפשר פונקציונליות חיונית של האתר, כמו גם עבור אנליטיקה, התאמה אישית ופרסום ממוקד. [מדינה פרטיות](#)

תחום	תעודת זהות		שם	להשתמש
Enterprise	T1195	.001	Supply Chain Compromise: Compromise Software Dependencies and Development Tools	XCSSET adds malicious code to a host's Xcode projects by enumerating CocoaPods <code>target_integrator.rb</code> files under the <code>/Library/Ruby/Gems</code> folder or enumerates all <code>.xcodeproj</code> folders under a given directory. XCSSET then downloads a script and Mach-O file into the Xcode project folder. ^[1]
Enterprise	T1082		System Information Discovery	XCSSET identifies the macOS version and uses <code>ioreg</code> to determine serial number. ^[1]
Enterprise	T1614	.001	System Location Discovery: System Language Discovery	XCSSET uses AppleScript to check the host's language and location with the command <code>user locale of (get system info)</code> . ^[1]
Enterprise	T1569	.001	System Services: Launchctl	XCSSET loads a system level launchdaemon using the <code>launchctl load -w</code> command from <code>/System/Librarby/LaunchDaemons/ssh.plist</code> . ^[1]
Enterprise	T1497	.003	Virtualization/Sandbox Evasion: Time Based Checks	Using the machine's local time, XCSSET waits 43200 seconds (12 hours) from the initial creation timestamp of a specific file, <code>.report</code> . After the elapsed time, XCSSET executes additional modules. ^[1]

References

1. [Mac Threat Response](#), Mobile Research Team. (2020, August 13). [The XCSSET Malware: Inserts Malicious Code Into Xcode Projects, Performs UXSS Backdoor Planting in Safari, and Leverages Two Zero-day Exploits](#). Retrieved October 5, 2021.

2. [Steven Du](#), [Dechao Zhao](#), [Luis Magisa](#), [Ariel Neimond Lazaro](#). (2021, April 16). [XCSSET Quickly Adapts to macOS 11 and M1-based Macs](#). Retrieved February 18, 2025.

3. [Microsoft Threat Intelligence](#). (2025, March 11). [New XCSSET malware adds new obfuscation, persistence techniques to infect Xcode projects](#). Retrieved April 2, 2025.
4. [Thomas Reed](#). (2020, April 21). [OSX.DubRobber](#). Retrieved October 5, 2021.

5. [Brandon Dalton](#). (2022, August 9). [A bundle of nerves: Tweaking macOS security controls to thwart application bundle manipulation](#). Retrieved September 27, 2022.

6. [Phil Stokes](#). (2021, February 16). [20 Common Tools & Techniques Used by macOS Threat Actors & Malware](#). Retrieved August 23, 2021.

אתר זה משתמש בטכנולוגיות כגון קובצי Cookie כדי לאפשר פונקציונליות חיונית של האתר, כמו גם עבור אנליטיקה, התאמה אישית ופרסום ממוקד. [מדינה פרטיות](#)